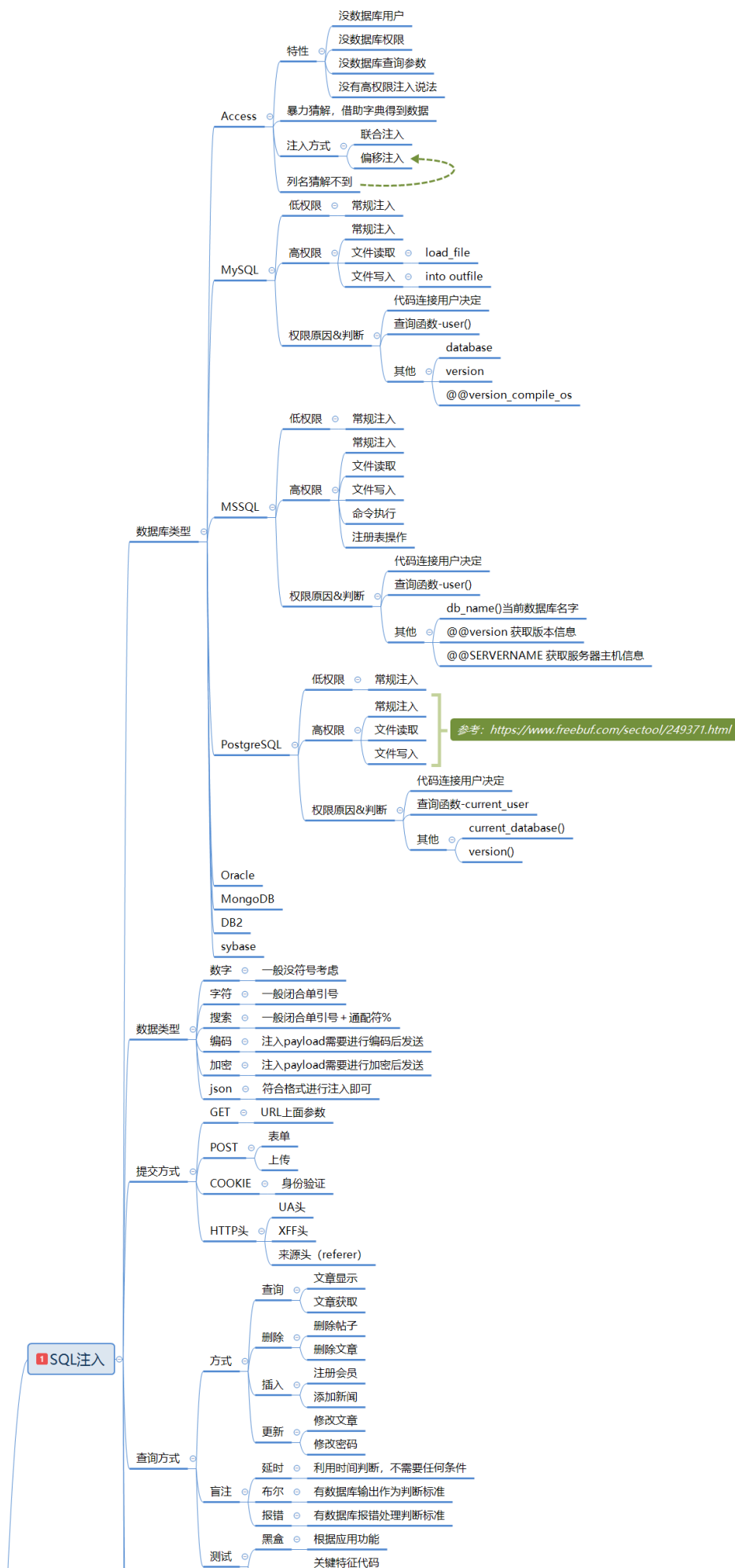
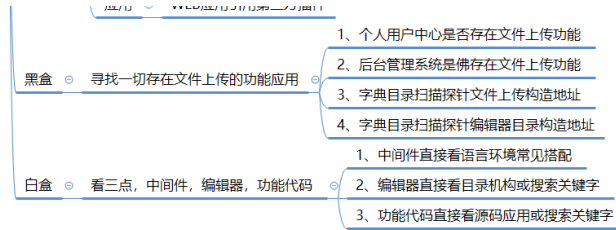


Day66 WEB攻防-Java安全&SPEL表达式&SSTI模版注入&XXE&JDBC&MyBatis注入



2 文件上传





通用安全漏洞

4 CSRF

-
- ```

graph TD
 A[条件] --> B[1、目标用户已经登录了网站，能够执行网站的功能。]
 A --> C[2、目标用户访问了攻击者构造的 URL。]
 C -- 探针且防御 --> D[1、看验证来源-修复]
 C -- 探针且防御 --> E[2、看凭证有无 token-修复]
 C -- 探针且防御 --> F[3、看关键操作有无验证-修复]
 F -- 流程 --> G[1、获取目标的触发数据包]
 F -- 流程 --> H[2、利用 CSRFTester 构造导出]
 F -- 流程 --> I[3、诱使受害者访问特定地址触发]
 I --> J[审计]

```
- 条件
- 1、目标用户已经登录了网站，能够执行网站的功能。
  - 2、目标用户访问了攻击者构造的 URL。
    - 探针且防御
      - 1、看验证来源-修复
      - 2、看凭证有无 token-修复
      - 3、看关键操作有无验证-修复
        - 流程
          - 1、获取目标的触发数据包
          - 2、利用 CSRFTester 构造导出
          - 3、诱使受害者访问特定地址触发
- 审计

## 5 SSRF

- 条件
  - 当前功能应用点利用服务器去解析拟提交的资源
- 功能
  - 分享
  - 转码
  - 翻译
  - 图片加载
  - 收藏
  - 信息探针
  - 内网扫描

| 语言     | PHP                     | Java               | curl                     | Perl           | ASP.NET             |
|--------|-------------------------|--------------------|--------------------------|----------------|---------------------|
| http   | ✓                       | ✓                  | ✓                        | ✓              | ✓                   |
| socket | with<br>cURL extensions | builtin<br>JDK 1.7 | before 7.40.0 不<br>支持SSL | ✓              | before<br>version 3 |
| ftp    | cURL extensions         | ✓                  | before 7.40.0 不<br>支持SSL | ✓              | ✓                   |
| dns    | ✓                       | ✓                  | ✓                        | ✓              | ✓                   |
| file   | ✓                       | ✓                  | ✓                        | ✓              | ✓                   |
| imap   | ✓                       | ✓                  | ✓                        | ✓              | ✓                   |
| mysql  | with<br>cURL extensions | ✓                  | ✓                        | ✓              | ✓                   |
| xml    | with<br>cURL extensions | ✓                  | ✓                        | ✓              | ✓                   |
| xmlrpc | with<br>cURL extensions | ✓                  | ✓                        | ✓              | ✓                   |
| ldap   | with<br>cURL extensions | ✓                  | ✓                        | ✓              | ✓                   |
| ldap2  | 需要子<br>程序, 不兼容          | ✓                  | ✓                        | 需要子<br>程序, 不兼容 | ✓                   |
| ldap3  | 需要子<br>程序, 不兼容          | ✓                  | ✓                        | 需要子<br>程序, 不兼容 | ✓                   |
| gopher | with<br>cURL extensions | ✓                  | ✓                        | ✓              | ✓                   |
| php    | 需要子<br>程序, 不兼容          | ✓                  | ✓                        | 需要子<br>程序, 不兼容 | ✓                   |

- 探针且防御 ○ SSRF常见安全修复防御方案. ○
- 1、禁用跳转
  - 2、禁用不需要的协议
  - 3、固定或限制资源地址
  - 4、错误信息统一-信息处理

- SSRF白盒可能出现的地方
- 1、功能点抓包指向代码块审计
  - 2、功能点函数定位代码块审计

- ```

graph LR
    A[审计] --- B[SSRF黑盒可能出现的地方]
    B --- C1[1.社交分享功能]
    B --- C2[2.转码服务]
    B --- C3[3.在线翻译]
    B --- C4[4.图片加载/下载]
    B --- C5[5.图片/文章收藏功能]
    B --- C6[6.云服务商厂商]
    B --- C7[7.网站采集，网站抓取的地方]
    B --- C8[8.数据库内置功能]
    B --- C9[9.邮件系统]
    B --- C10[10.编码处理,属性信息处理，文件处理]
    B --- C11[11.未公开的api实现以及其他扩展调用URL的功能]
    B --- C12[12.从远程服务器请求资源]
  
```

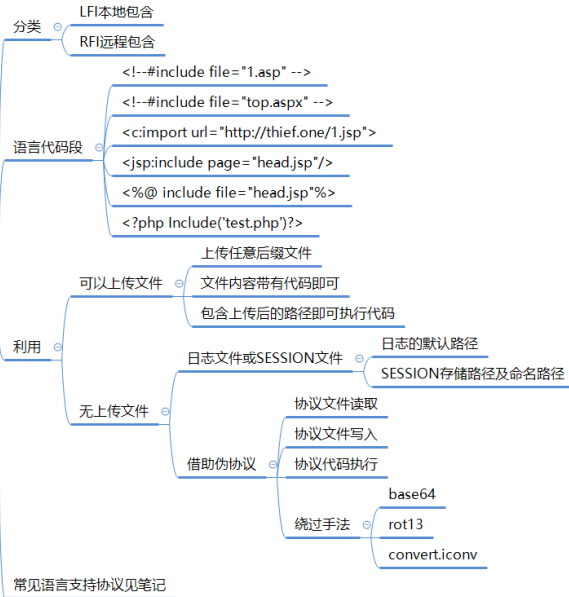
6 XXE&XML

- ```

graph LR
 Root[前置] --- A[理由：传输和存储数据]
 Root --- B[危害：文件读取，端口探针等]
 Root --- C[Content-Type]
 Root --- D[黑盒]
 Root --- E[白盒]
 Root --- F[有回显]
 Root --- G[无回显]
 Root --- H[伪协议玩法]
 Root --- I[禁用dtd实体引用]
 Root --- J[过滤关键词：<!DOCTYPE和<!ENTITY，或者SYSTEM和PUBLIC]
 D --- D1[数据格式]
 D --- D2[svg&excel引用]
 E --- E1[1、可通过应用功能追踪代码定位审计]
 E --- E2[2、可通过脚本特定函数搜索定位审计]
 E --- E3[3、可通过伪协议玩法绕过相关修复等]
 F --- F1[file读取文件]
 F --- F2[http带外访问]
 G --- G1[file读取文件-先读取]
 G --- G2[http带外访问-加载实体]
 G --- G3[dtd实体带外访问-将数据参数发送接收文件接收数据处理]
 H --- H1[见笔记图，后期文件包含会讲]

```

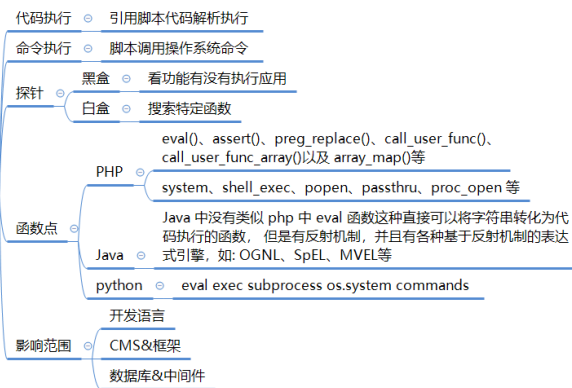
## 文件包含



## 其他文件操作安全



## RCE



## PHP



## 反序列化

### JAVA

#### 属性

- `__toString()`: 把类当做字符串使用时触发
- `__sleep()`: `serialize()`函数会检查类中是否存在一个魔术方法 `__sleep()` 如果存在, 该方法会被优先调用
- `public` (公共的): 在本类内部、外部类、子类都可以访问
- `protect` (受保护的): 只有本类或子类或父类中可以访问
- `private` (私人的): 只有本类内部可以使用
  - 序列化数据显示:
    - `private` 属性序列化的时候格式是 `%00 类名%00 成员名`
    - `protect` 属性序列化的时候格式是 `%00*%00 成员名`

#### 利用

- 单纯的魔术方法逻辑调用
- PHP语言的特性漏洞-如 CVE-2016-7124
- 魔术方法内置原生类
  - 1、获取魔术方法对应原生类
  - 2、利用原生类官方说明配合
- 字符串逃逸&Phar
  - 后面专题讲到

#### 原理

- 序列化: 把 Java 对象转换为字节序列的过程。
- 反序列化: 把字节序列恢复为 Java 对象的过程。

#### 发现

- Serializable Externalizable 接口、fastjson、jackson、gson、ObjectInputStream.read、ObjectObjectInputStream.readUnshared、XMLDecoder.read、ObjectYaml.loadXStream.fromXML、ObjectMapper.readValue、JSON.parseObject 等
- 功能
  - http参数, cookie, sesion, 存储方式可能是base64(r00), 压缩后的base64(H4s), MII等。Serlets http, Sockets, Session管理器, 包含的协议就包括JMX, RMI, JMS, JNDI等(\xac \xed)\xmlstream.XmlEncoder等(http Body: Content-type: application/xml) json(jacksonfastjson)http请求中包含
- 数据特性
  - 一段数据以 `r00AB` 开头, 你基本可以确定这串就是 JAVA 序列化 base64 加密的数据。
  - 或者如果以 `aced` 开头, 那么他就是这一段 java 序列化的 16 进制。

#### 利用

- Ysoserial
  - 无组件
  - 有组件
- 特定的组件利用
  - shiro
  - jboos

### Python

#### 解释

- 文件&字符串&字节流&对象相互转换的过程

#### 原理

- 序列化调用魔术方法
- 反序列化调用魔术方法

#### 函数&魔术方法

- 函数使用:
  - `pickle.dump(obj, file)`: 将对象序列化后保存到文件
  - `pickle.load(file)`: 读取文件, 将文件中的序列化内容反序列化为对象
  - `pickle.dumps(obj)`: 将对象序列化成字符串格式的字节流
  - `pickle.loads(bytes_obj)`: 将字符串格式的字节流反序列化为对象
- 魔术方法:
  - `__reduce__()` 反序列化时调用
  - `__reduce_ex__()` 反序列化时调用
  - `__setstate__()` 反序列化时调用
  - `__getstate__()` 序列化时调用

#### 利用

- 注意当前构造版本和目标版本对应
- 注意当前是否需要编码、转换等

#### 白盒

- 搜索特定函数
- 使用bandit

### 访问权限

#### 越权

- 水平同级用户
  - 用户信息获取时未对用户与 ID 比较判断直接查询等
- 垂直低高用户
  - 数据库中用户类型编号接受篡改或高权限操作未验证等

#### 访问控制

- 验证丢失
  - 未包含引用验证代码文件等
- 没有验证
  - 支持空口令、匿名、白名单等

#### 脆弱验证

- Cookie
  - JWT
  - Session
- 不安全的验证逻辑等

### 购买支付

#### 安全点

- 价格和数量
- 产品和订单编号
- 支付模式&接口数据
- 折扣优惠券积分等重复使用&再获取

#### 安全问题

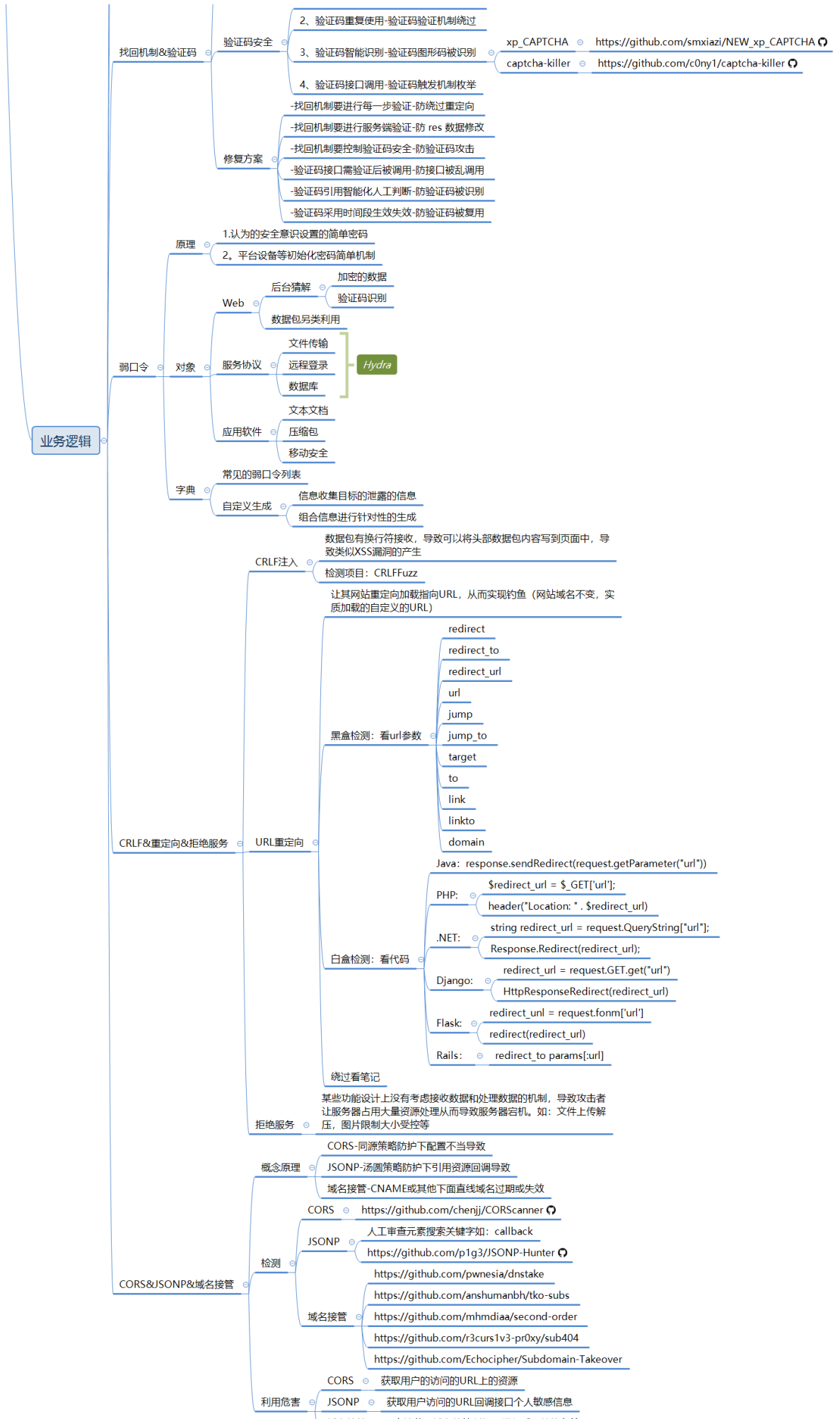
- 1、商品购买-数量&价格&编号等
- 2、支付模式-状态&接口&负数等
- 3、折扣处理-优惠券&积分&重放等

#### 挖掘&修复

- 1、金额以数据库定义为准
  - 2、购买数量限制为正整数
  - 3、优惠券固定使用后删除
  - 4、订单生成后检测对应值
- 功能点抓包造代码测试

#### 找回机制

- 1、用回显状态判断-res 前端判断不安全
- 2、用用户名重定向-修改标示绕过验证
- 3、验证码回显显示-验证码泄漏验证虚设
- 4、验证码简单机制-验证码过于简单爆破





## 1.知识点

- 1、ASP-SQL注入-Access数据库
- 2、ASP-默认安装-数据库漏洞下载
- 3、ASP-IIS-CVE&短文件&解析&写入

- 
- 1、PHP-MYSQL-SQL注入-常规查询
  - 2、PHP-MYSQL-SQL注入-跨库查询
  - 3、PHP-MYSQL-SQL注入-文件读写

- 
- 1、PHP-MYSQL-SQL注入-数据请求类型
  - 2、PHP-MYSQL-SQL注入-数据请求方法
  - 3、PHP-MYSQL-SQL注入-数据请求格式

- 
- 1、PHP-MYSQL-SQL注入-方式增删改查
  - 2、PHP-MYSQL-SQL注入-布尔&延迟&报错
  - 3、PHP-MYSQL-SQL注入-数据回显&报错处理

- 
- 1、PHP-MYSQL-SQL注入-二次注入&利用条件
  - 2、PHP-MYSQL-SQL注入-堆叠注入&利用条件
  - 3、PHP-MYSQL-SQL注入-带外注入&利用条件

- 
- 1、注入工具-SQLMAP-常规猜解&字典配置
  - 2、注入工具-SQLMAP-权限操作&文件命令
  - 3、注入工具-SQLMAP-Tamper&使用&开发
  - 4、注入工具-SQLMAP-调试指纹&风险等级

- 
- 1、PHP-原生态-文件上传-检测后缀&黑白名单
  - 2、PHP-原生态-文件上传-检测信息&类型内容
  - 3、PHP-原生态-文件上传-函数缺陷&逻辑缺陷
  - 4、PHP-原生态-文件上传-版本缺陷&配置缺陷

- 
- 1、PHP-中间件-文件上传-CVE&配置解析
  - 2、PHP-编辑器-文件上传-第三方引用安全

- 3、PHP-CMS源码-文件上传-已知识别到利用

- 
- 1、文件上传-安全解析方案-目录权限&解码还原
  - 2、文件上传-安全存储方案-分站存储&OSS对象

- 
- 1、文件包含-原理&分类&危害-LFI&RFI
  - 2、文件包含-利用-黑白盒&无文件&伪协议

- 
- 1、文件安全-前后台功能点-下载&读取&删除
  - 2、目录安全-前后台功能点-目录遍历&目录穿越

- 
- 1、XSS跨站-输入输出-原理&分类&闭合
  - 2、XSS跨站-分类测试-反射&存储&DOM

- 
- 1、XSS跨站-MXSS&UXSS
  - 2、XSS跨站-SVG制作&配合上传
  - 3、XSS跨站-PDF制作&配合上传
  - 4、XSS跨站-SWF制作&反编译&上传

- 
- 1、XSS跨站-攻击利用-凭据盗取
  - 2、XSS跨站-攻击利用-数据提交
  - 3、XSS跨站-攻击利用-网络钓鱼
  - 4、XSS跨站-攻击利用-溯源综合

- 
- 1、XSS跨站-安全防护-CSP策略
  - 2、XSS跨站-安全防护-HttpOnly
  - 3、XSS跨站-安全防护-XSSFilter

- 
- 1、CSRF-原理&检测&利用&防御
  - 2、CSRF-防御-Referer策略隐患
  - 3、CSRF-防御-Token校验策略隐患

- 
- 1、SSRF-原理-外部资源加载
  - 2、SSRF-利用-伪协议&无回显

- 3、SSRF-挖掘-业务功能&URL参数

- 
- 1、RCE-原理-代码执行&命令执行
  - 2、RCE-黑白盒-过滤绕过&不回显方案

- 
- 1、XXE&XML-原理-用途&外实体&安全
  - 2、XXE&XML-黑盒-格式类型&数据类型
  - 3、XXE&XML-白盒-函数审计&回显方案

- 
- 1、PHP-反序列化-应用&识别&函数
  - 2、PHP-反序列化-魔术方法&触发规则
  - 3、PHP-反序列化-联合漏洞&POP链构造

- 
- 1、PHP-反序列化-属性类型&显示特征
  - 2、PHP-反序列化-CVE绕过&字符串逃逸
  - 3、PHP-反序列化-原生类生成&利用&配合

- 
- 1、PHP-反序列化-开发框架类项目
  - 2、PHP-反序列化-Payload生成项目
  - 3、PHP-反序列化-Payload生成综合项目

- 
- 1、JavaScript-作用域&调用堆栈
  - 2、JavaScript-断点调试&全局搜索
  - 3、JavaScript-Burp算法模块使用

- 
- 1、JavaScript-反调试&方法&绕过
  - 2、JavaScript-代码混淆&识别&还原

- 
- 1、JavaScript安全-泄漏配置信息
  - 2、JavaScript安全-获取接口测试
  - 3、JavaScript安全-代码逻辑分析
  - 4、JavaScript安全-框架漏洞检测

- 
- 1、Java安全-SQL注入-JDBC&MyBatis

- 2、Java安全-XXE注入-Reader&Builder
- 3、Java安全-SSTI模版-Thymeleaf&URL
- 4、Java安全-SPEL表达式-SpringBoot框架

## 2.演示案例

```
1 https://github.com/bewhale/JavaSec
2 https://github.com/j3ers3/Hello-Java-Sec
3 https://mp.weixin.qq.com/s/Z04tpz9ys6kCIryNhA5nYw
```

### 2.1 Java安全-SQL注入-JDBC&MyBatis

```
1 -JDBC
2 1、采用Statement方法拼接SQL语句
3 2、PreparedStatement会对SQL语句进行预编译，但如果直接采取拼接的方式构造SQL，此时进行预编译也无用。
4 3、JdbcTemplate是Spring对JDBC的封装，如果使用拼接语句便会产生注入
5 安全写法：SQL语句占位符（?） + PreparedStatement预编译
6
7 -MyBatis
8 MyBatis支持两种参数符号，一种是#，另一种是$，#使用预编译，$使用拼接SQL。
9 1、order by注入：由于使用#{ }会将对象转成字符串，形成order by "user" desc造成错误，因此很多研发会
 采用${ }来解决，从而造成注入。
10 2、like 注入：模糊搜索时，直接使用'%#{q}%' 会报错，部分研发图方便直接改成'%${q}%'从而造成注入。
11 3、in注入：in之后多个id查询时使用 # 同样会报错，从而造成注入。
12
13 -代码审计案例：inxedu后台MyBatis注入
```

### 2.2 Java安全-XXE注入-Reader&Builder

```
1 XXE (XML External Entity Injection)，XML外部实体注入，当开发人员配置其XML解析功能允许外部实体引
 用时，攻击者可利用这一可引发安全问题的配置方式，实施任意文件读取、内网端口探测、命令执行、拒绝服务等攻
 击。
2 -XMLReader
3 -SAXReader
4 -SAXBuilder
5 -Unmarshaller
6 -DocumentBuilder
7 /**
8 * 审计的函数
9 * 1. XMLReader
10 * 2. SAXReader
11 * 3. DocumentBuilder
12 * 4. XMLStreamReader
13 * 5. SAXBuilder
```

```
14 * 6. SAXParser
15 * 7. SAXSource
16 * 8. TransformerFactory
17 * 9. SAXTransformerFactory
18 * 10. SchemaFactory
19 * 11. Unmarshaller
20 * 12. XPathExpression
21 */
```

## 2.3 Java安全-SSTI模版-Thymeleaf&URL



1 SSTI(Server Side Template Injection) 服务器模板注入，服务端接收了用户的输入，将其作为 web 应用模板内容的一部分，在进行目标编译渲染的过程中，执行了用户插入的恶意内容。

2 1、URL作视图

3 2、velocity

4 3、Thymeleaf

5 其他语言参考：<https://www.cnblogs.com/bmjoker/p/13508538.html>

## 2.4 Java安全-SPEL表达式-SpringBoot框架



1 SpEL (Spring Expression Language) 表达式注入，是一种功能强大的表达式语言、用于在运行时查询和操作对象图，由于未对参数做过滤可造成任意命令执行。

2 1、Spring表达式

3 2、Spring反射绕过

4 参考：<https://www.jianshu.com/p/e3c77c053359>